

Talent-X

Document 3 — Sécurité, RGPD et gouvernance des données

Cadre de conformité, protections techniques et gouvernance des données sensibles — révision intégrant l'audit de conception.

Référence	TX-SEC-003
Version	2.0
Date	4 juin 2026
Statut	Document technique détaillé — révision 2.0 (corrections d'audit + améliorations)

Ce document fait partie du lot documentaire Talent-X. Il décrit le cadre de sécurité et de conformité RGPD. Il s'appuie sur l'architecture (TX-ARCH-001), le modèle de données (TX-DATA-006) et les contrats d'API (TX-SPEC-002).

Avertissement. Ce document est une base de travail technique et organisationnelle ; il ne constitue pas un avis juridique. La qualification exacte des traitements, le caractère obligatoire de l'analyse d'impact, le statut des transferts hors UE et la place des mineurs doivent être validés par un conseil juridique ou un DPO compétent avant la mise en production.

Historique des révisions

Version	Date	Nature des modifications
1.0	8 avril 2026	Version initiale.
2.0	4 juin 2026	Section transferts internationaux (push APNs/FCM, email) ; section mineurs (art. 8) ; registre des traitements (art. 30) ; droits étendus (limitation art. 18, opposition art. 21) ; DPIA requalifiée probablement obligatoire et renvoyée à un document dédié (TX-DPIA-007) ; notification des violations sous 72 h et registre ; registre des sous-traitants (art. 28) ; authentification renforcée (RS256, rotation et détection de réutilisation, reset anti-énumération, 2FA) ; chiffrement applicatif précisé et garde des clés de sauvegarde ; mise en cohérence avec TX-DATA-006 et TX-SPEC-002.

Sommaire

Historique des révisions	2
1. Enjeu réglementaire et positionnement	3
2. Gouvernance des données	3
3. Catégories de données traitées.....	3
4. Bases juridiques.....	4
5. Registre des traitements (art. 30)	4
6. Consentement.....	4
7. Données des mineurs (art. 8).....	5
8. Droits des personnes concernées	5
9. Rétention, portabilité et effacement	6
9.1 Processus d'export	6
9.2 Processus d'effacement.....	6
10. Transferts internationaux de données	6
11. Architecture de sécurité.....	7
12. Chiffrement et gestion des clés	7
13. Menaces principales et mesures associées	7
14. Journalisation, auditabilité et preuves.....	8
15. Gestion des incidents et violations de données	8
16. Analyse d'impact (DPIA / AIPD)	8
17. Sous-traitants et accords de traitement (art. 28).....	9
18. Checklist de mise en production.....	9
19. Décisions à valider	9
20. Conclusion	10

1. Enjeu réglementaire et positionnement

Talent-X traite des données d'identité, d'usage et de performance sportive. Selon la nature exacte des indicateurs collectés, ces informations peuvent relever des données sensibles au sens de l'article 9 du RGPD, notamment lorsqu'elles permettent d'inférer des éléments relatifs à la santé, aux capacités physiques ou au suivi corporel.

Le produit doit donc être conçu comme un système manipulant des données à fort enjeu de confidentialité, selon une logique de privacy by design et by default (art. 25) : minimisation, sécurité par défaut, et conformité exécutable plutôt que documentaire — consentement prouvable, droits activables, suppression réelle, protection technique effective et journalisation maîtrisée.

Deux points de cadrage conditionnent la conformité et doivent être tranchés : la place des **mineurs** (section 7) et le périmètre exact des données relevant de l'article 9. Ils sont repris en section 19. ⚠ **À valider.**

2. Gouvernance des données

Responsable de traitement	L'exploitant de Talent-X, même s'il s'agit d'une personne physique et non d'une société.
Sous-traitants	OVHcloud (hébergement) et les services tiers de stockage, d'email et de notifications, selon leur rôle réel (voir section 17).
DPO	Désignation à évaluer : elle peut être obligatoire si le suivi à grande échelle de données de santé constitue une activité de base. ⚠ À confirmer.
Point d'attention	La qualification des traitements et les formalités associées doivent être revues avant mise en production par un conseil juridique ou un DPO.

3. Catégories de données traitées

Catégorie	Exemples	Sensibilité	Mesures attendues
Identité	Nom, prénom, email, photo	Élevée	Accès limité, chiffrement au repos, journalisation contrôlée.
Authentification	Hash de mot de passe, refresh tokens, secret 2FA	Critique	Hachage fort, rotation, secrets externalisés.
Profil sportif	Sport, niveau, rôle, groupe	Élevée	Minimisation et contrôle d'accès par appartenance.
Performances	Temps, charges, RPE, notes	Très élevée	Consentement explicite, accès conditionné, conservation bornée.
Identifiants d'appareil	Device tokens push (APNs/FCM)	Moyenne à élevée	Transfert hors UE encadré, contenu de push minimal (section 10).
Logs applicatifs	Traçabilité des appels, erreurs, actions	Moyenne à élevée	Pseudonymisation partielle, rétention courte.

Catégorie	Exemples	Sensibilité	Mesures attendues
Exports / sauvegardes	Instantanés structurés des données	Critique	Chiffrement, durée de vie limitée, accès restreint.

4. Bases juridiques

- Données nécessaires à la création du compte et à la fourniture du service : exécution du contrat (art. 6(1)(b)).
- Données sportives sensibles : consentement explicite (art. 9(2)(a)), séparé, tracé et révocable.
- Emails de fonctionnement strictement nécessaires : exécution du service ou intérêt légitime selon le cas.
- Journalisation et sécurité : intérêt légitime, avec minimisation et rétention courte.
- Analytics non indispensables : données agrégées et anonymisées ; éviter toute collecte non justifiée au MVP.

Vigilance particulière sur les données mesurant la charge, la récupération, le ressenti ou les paramètres corporels : même « sportives » dans l'intention produit, elles peuvent devenir sensibles dès lors qu'elles révèlent indirectement des informations de santé. En cas de doute, le consentement explicite (art. 9) est la base la plus prudente.

5. Registre des traitements (art. 30)

Vue synthétique des traitements à tenir à jour. Les transferts hors UE (notifications) sont signalés et détaillés en section 10.

Traitement	Finalité	Base	Données	Conservation	Destinataires
Comptes	Fournir le service	Contrat (6.1.b)	Identité, auth	Vie du compte	OVH (UE)
Suivi de performance	Entraînement, progression	Consentement (9.2.a)	Performances	Compte actif + délai	Coach lié
Collaboration	Feedback, suivi	Consentement / contrat	Commentaires	Compte actif	Coach, athlète liés
Notifications push	Informer l'utilisateur	Consentement / int. légitime	Device tokens, contenu minimal	Vie du token	APNs/FCM (hors UE) ⚠
Emails de compte	Sécurité, fonctionnement	Contrat / int. légitime	Email	Vie du compte	SMTP (à vérifier) ⚠
Journalisation	Sécurité, diagnostic	Intérêt légitime	Logs pseudonymisés	90 jours	Interne
Sauvegardes	Continuité, restauration	Intérêt légitime	Toutes (chiffrées)	30 j roulants	OVH (UE)
Droits RGPD	Export, effacement	Obligation légale	Toutes	Export 7 j	Interne

6. Consentement

- Écran dédié pendant l'onboarding, sans case pré-cochée.

- Consentements séparés : traitement des données de performance, accès du coach à ces données, communications non essentielles.
- Historisation de la version du texte, de l'horodatage et de l'utilisateur concerné (table consents, append-only, cf. TX-DATA-006 §4.2).
- Retrait à tout moment depuis les paramètres, aussi simple que de le donner (art. 7(3)).
- Propagation du retrait aux traitements subséquents sous un délai maîtrisé et documenté.

Le retrait ne se limite pas à masquer une option : il enclenche une logique métier et opérationnelle (arrêt des nouveaux traitements, blocage des accès dépendants, purge ou anonymisation). Le consentement « accès coach » est traité comme une **condition d'autorisation** (RB-08), et non comme un simple réglage d'interface. Les contrats correspondants figurent dans TX-SPEC-002 (GET/PUT /users/me/consents).

7. Données des mineurs (art. 8)

 **Décision structurante à trancher.** Une application de suivi sportif peut concerner des mineurs (sport jeunes, clubs). Trois options, à arbitrer avec un conseil juridique :

- Exclure les mineurs au MVP : âge minimal annoncé (par ex. 18 ans), réservé aux majeurs, et hors-périmètre explicite (cohérent avec TX-PRD-005).
- Inclure les mineurs avec encadrement : vérification d'âge à l'inscription et recueil du consentement parental pour les moins de 15 ans (majorité numérique en France, art. 8), avec adaptation des bases juridiques et des textes.
- Repousser la décision en exigeant une déclaration de majorité au MVP, en attendant l'arbitrage.

Quelle que soit l'option, le modèle de données prévoit le champ birth_date (TX-DATA-006) pour permettre une vérification d'âge ultérieure sans refonte.

8. Droits des personnes concernées

Les droits sont opérationnalisés par des fonctions du produit, et non traités au cas par cas. Le tableau renvoie aux contrats et règles correspondants.

Droit	Article	Mise en œuvre	Réf.
Information	13-14	Politique de confidentialité et écrans d'onboarding	—
Accès	15	Consultation dans l'application et export des données	SPEC §8.2
Rectification	16	Édition du profil ; correction tracée de l'historique, sans modification silencieuse	RB-06
Effacement	17	Suppression de compte (asynchrone) puis purge	§9.2
Portabilité	20	Export structuré et réutilisable	§9.1
Limitation	18	Procédure de gel du traitement sur demande	 à outiller
Opposition	21	Retrait de consentement et opposition aux traitements concernés	§6

Droit	Article	Mise en œuvre	Réf.
Retrait du consentement	7(3)	À tout moment, aussi simple que de le donner	SPEC §8.2

9. Rétention, portabilité et effacement

Type de donnée	Durée cible	Motif	Action en fin de vie
Compte actif	Durée de vie du compte	Exécution du service	Suppression ou anonymisation après demande.
Performances	Compte actif + délai limité	Suivi sportif	Purge ou anonymisation selon la politique.
Logs techniques	90 jours	Sécurité et diagnostic	Suppression automatique.
Sauvegardes	Fenêtre roulante de 30 jours	Continuité et restauration	Expiration automatique et écrasement.
Exports	7 jours maximum	Portabilité	Suppression automatique du fichier temporaire.

9.1 Processus d'export

- Demande authentifiée par l'utilisateur, traitée de façon asynchrone (202 Accepted + suivi, cf. TX-SPEC-002).
- Compilation d'un export structuré (JSON ou archive) par un worker dédié.
- Mise à disposition temporaire via un lien à durée de vie courte ; traçabilité de la demande, de la génération et du téléchargement.

9.2 Processus d'effacement

- Demande initiée depuis l'application, avec confirmation forte pour éviter les suppressions accidentelles.
- Suppression logique immédiate (`deleted_at`), puis purge définitive par tâche planifiée.
- Suppression des médias, révocation des jetons, retrait des appartenances de groupe.
- Délai réel d'effacement : jusqu'à la durée de rétention des sauvegardes (30 jours). Ce délai doit être annoncé dans la politique de confidentialité, et non laissé implicite.
- Anonymisation plutôt que suppression pour les données conservées pour l'intégrité (ex. journal d'audit, cf. TX-DATA-006).

10. Transferts internationaux de données

La promesse de résidence des données dans l'UE (OVHcloud) connaît des exceptions à encadrer, principalement les notifications push.

- Notifications push : APNs (Apple) et FCM (Google) sont opérés hors UE. Les device tokens et le contenu des notifications constituent un transfert international de données personnelles.
- Vérifier le mécanisme de transfert applicable (décision d'adéquation, clauses contractuelles types, ou cadre de transfert en vigueur) et le documenter. ⚠ Validation juridique requise.

- Minimiser le contenu des push : aucun résultat de performance, donnée de santé ou information sensible dans le corps de la notification ; se limiter à un signal et à un identifiant de ressource.
- Emails de compte : vérifier la localisation du fournisseur SMTP et le traiter comme un transfert si nécessaire. ⚠
- Consigner ces transferts au registre des traitements (section 5) et dans la politique de confidentialité.

11. Architecture de sécurité

La sécurité combine mesures d'architecture, contrôles techniques et processus d'exploitation : réduire la surface d'exposition, contrôler les accès, chiffrer ce qui doit l'être, et conserver une capacité d'investigation sans exposer inutilement de données personnelles. Le détail d'architecture figure dans TX-ARCH-001.

- Authentification : mots de passe hachés (bcrypt ou Argon2id), access token court signé RS256, refresh token opaque rotatif avec détection de réutilisation, déconnexion (logout / logout-all).
- 2FA TOTP optionnelle, recommandée pour les comptes coach qui concentrent les données de nombreux athlètes.
- Réinitialisation de mot de passe : token à usage unique et expirant, réponse neutre (anti-énumération de comptes).
- Autorisation : RBAC + appartenance + ownership + consentement, appliqués via guards (TX-ARCH-001 §9 ; matrice dans TX-SPEC-002 §6).
- Transport : TLS 1.3, HSTS et rejet du HTTP clair en production.
- Validation : DTO et whitelisting sur toutes les entrées d'API ; idempotence des écritures sensibles.
- Secrets : coffre ou gestionnaire de secrets en production ; aucun secret dans le dépôt. ⚠ Outil à choisir.
- Journalisation : logs structurés et corrélés, sans fuite de jetons ni de données sensibles.

12. Chiffrement et gestion des clés

- En transit : TLS 1.3 de bout en bout côté reverse proxy.
- Au repos : chiffrement des volumes de base de données et des sauvegardes.
- Chiffrement applicatif de champs : périmètre à décider via la DPIA. Candidats : secret 2FA (two_factor_secret) et, le cas échéant, certains champs libres sensibles ; schéma randomisé (non déterministe) sauf besoin de recherche. ⚠
- Gestion des clés : clés de chiffrement des sauvegardes conservées hors du nœud principal (une compromission du nœud ne doit pas compromettre les sauvegardes) ; rotation organisée et séparation des accès.

13. Menaces principales et mesures associées

Menace	Impact	Mesures clés
Credential stuffing	Prise de compte	Rate limiting, temporisation, surveillance, politique de mot de passe.

Menace	Impact	Mesures clés
Vol de JWT	Usurpation d'accès	Durée de vie courte, stockage sécurisé mobile, HTTPS uniquement.
Réutilisation de refresh token	Usurpation de session	Rotation + détection de réutilisation (révocation de la famille).
Injection SQL	Altération ou fuite	Requêtes paramétrées, validation, revues de code.
Escalade de privilèges	Accès aux données d'un tiers	RBAC + appartenance + ownership + consentement côté service.
Accès non consenti du coach	Atteinte à la confidentialité	Consentement « accès coach » comme condition d'autorisation (RB-08).
Exposition via logs	Fuite indirecte de PII	Redaction et politique de logs stricte.
Transfert hors UE non maîtrisé	Non-conformité, exposition	Minimisation des push, documentation et garanties contractuelles.
Compromission d'un export	Fuite massive ciblée	Fichiers chiffrés, durée de vie courte, accès authentifié.
Incident infrastructure	Indisponibilité ou perte	Sauvegardes, PRA, monitoring, tests de restauration.

14. Journalisation, auditabilité et preuves

- Horodatage fiable des consentements, demandes d'export et suppressions (journal d'audit, TX-DATA-006 §6.2).
- Traçage des opérations administratives et des actions de sécurité significatives.
- Pseudonymisation autant que possible des traces de monitoring.
- Durées de conservation courtes et purges automatiques sur les logs.

La logique de preuve doit être assez robuste pour répondre à une demande utilisateur ou à un audit, sans que le système de logs devienne lui-même une source secondaire de fuite.

15. Gestion des incidents et violations de données

- Détection par monitoring, alertes ou remontée utilisateur.
- Qualification rapide : confidentialité, intégrité, disponibilité.
- Confinement : révocation de jetons, suspension d'un flux, retrait d'un composant si nécessaire.
- Investigation à partir de logs et métriques corrélés.
- Remédiation, restauration, communication et capitalisation post-incident.

Violation de données personnelles. Notification à la CNIL dans les 72 heures lorsque la violation présente un risque pour les droits et libertés des personnes ; information des personnes concernées en cas de risque élevé ; tenue d'un registre interne des violations, y compris celles non notifiées.

16. Analyse d'impact (DPIA / AIPD)

Caractère obligatoire. Le traitement portant de façon systématique et à grande échelle sur des données permettant d'inférer la santé, l'analyse d'impact est **probablement obligatoire** (art. 35) — et non seulement recommandée. Elle doit être réalisée avant la mise en

production et fera l'objet d'un document dédié (TX-DPIA-007). ⚠ Caractère obligatoire à confirmer avec le DPO.

Contenu minimum à préparer :

- Description précise des traitements, des catégories de données et des acteurs.
- Justification de la nécessité et de la proportionnalité.
- Analyse des risques pour les droits et libertés des personnes concernées.
- Mesures de réduction des risques : techniques, organisationnelles et contractuelles.
- Décision sur la mise en production et plan de revue périodique.

17. Sous-traitants et accords de traitement (art. 28)

Tout sous-traitant accédant à des données personnelles doit être lié par un accord de traitement (art. 28). Registre à tenir à jour :

Sous-traitant	Rôle	Localisation	Accord (DPA)	Hors UE
OVHcloud	Hébergement, stockage, sauvegardes	UE	À signer	Non
Fournisseur SMTP	Emails de compte	À vérifier ⚠	À signer	À vérifier
Apple (APNs)	Notifications push iOS	États-Unis	Conditions Apple	Oui ⚠
Google (FCM)	Notifications push Android	États-Unis	Conditions Google	Oui ⚠

18. Checklist de mise en production

- Politique de confidentialité et textes de consentement relus (incluant le délai réel d'effacement, jusqu'à 30 jours).
- Registre des traitements (art. 30) tenu à jour.
- Analyse d'impact (DPIA) réalisée et décision de mise en production prise.
- Accords de sous-traitance (art. 28) signés ; transferts hors UE documentés et minimisés.
- Décision sur la place des mineurs prise et reflétée dans l'inscription.
- Processus d'export et d'effacement testés de bout en bout.
- Chiffrement, rotation des secrets, garde des clés et sauvegardes vérifiés.
- Logs masqués (redacted), monitoring actif et registre des violations en place.
- Dossier de sécurité minimal disponible pour exploitation et audit.

19. Décisions à valider

Sujet	Recommandation par défaut	Réf.
Place des mineurs	Majeurs uniquement au MVP ; consentement parental si ouverture	7
Caractère obligatoire de la DPIA	La traiter comme obligatoire ; confirmer avec le DPO	16

Sujet	Recommandation par défaut	Réf.
Mécanisme de transfert APNs/FCM	Documenter et vérifier les garanties applicables	10, 17
Localisation du fournisseur SMTP	À vérifier ; traiter comme transfert si hors UE	10, 17
Désignation d'un DPO	À évaluer selon l'activité de base	2
Périmètre du chiffrement applicatif	Secret 2FA ; étendre selon la DPIA	12
Outil de gestion des secrets	À choisir	11
Valeurs de consents.type	Aligner avec TX-DATA-006	6

20. Conclusion

Pour Talent-X, la sécurité et le RGPD ne sont pas une surcouche documentaire ajoutée en fin de projet : ce sont des capacités natives du produit. Cette révision rend la conformité plus exécutable — consentement conditionnant réellement l'accès du coach, droits opérationnalisés, transferts hors UE encadrés, violations traitées dans les délais légaux — et explicite les points qui exigent une décision ou une validation juridique.

Les arbitrages de la section 19, au premier rang desquels la place des mineurs, le caractère obligatoire de la DPIA et l'encadrement des transferts push, doivent être tranchés avant la mise en production. L'analyse d'impact dédiée (TX-DPIA-007) en est le prolongement naturel.